

Questionário de conformidade — Portaria MTP 671/2021

Resposta consolidada do desenvolvimento · Fase 1 (Auditoria Legal) · 07 de agosto de 2026

Como este documento foi produzido

O questionário foi respondido por **duas auditorias independentes** do mesmo código, feitas em paralelo e sem acesso uma à outra. Este documento é a consolidação das duas: onde concordaram, o veredicto é o comum; onde divergiram, prevaleceu o que a evidência no código sustenta, e a divergência está registrada.

Cada resposta cita **tabela, coluna, gatilho ou arquivo**, para que a consultoria possa conferir em vez de confiar.

Quadro-resumo

#	Item	Resposta
1	Armazenamento das marcações originais	PARCIAL
2	Marcações imutáveis	NÃO
3	Trilha de auditoria	SIM*
4	Log de alterações (inclusive fora do fluxo)	SIM*
5	Identificação de quem alterou	PARCIAL
6	Geração de AFD	PARCIAL
7	Geração de AEJ	NÃO
8	Espelho de Ponto	SIM*
9	Assinatura digital ICP-Brasil	NÃO
10	Histórico completo e imutável	PARCIAL

* Sim, com ressalvas — descritas no item.

O essencial em três linhas

O sistema **registra e rastreia bem**: hash por marcação, trilha de banco para toda inclusão, alteração e exclusão, e fluxo de ajuste com justificativa e aprovação.

O que **não** está conforme é o núcleo probatório: a marcação original pode ser sobrescrita pela tela, o AFD sai fora do leiaute, não existe AEJ e não há assinatura ICP-Brasil.

Há ainda uma **exceção de acesso fora do modelo de papéis**, gravada em código — detalhada no item 11.

1

Onde ficam armazenadas as marcações originais

ARP — inalterabilidade do registro original

PARCIAL

As três tabelas existem; a original é sobrescrita na edição e não há NSR.

Tabela	Papel	Campos relevantes
ponto_marcacoes	marcação	data_marcacao, hora_marcacao, tipo_marcacao, hash_marcacao (SHA-256, gatilho <i>trigger_gerar_hash_marcacao</i> no INSERT), <i>marcacao_original</i> (booleano), <i>created_by</i> , <i>ip_origem</i> , <i>user_agent</i> , <i>dispositivo</i> , <i>latitude/longitude</i> , <i>endereco_geolocalizacao</i> , <i>dentro_cerca</i> , <i>distancia_metros</i> , <i>geofence_ref</i> , <i>selfie_url</i> , <i>classificacao_clt</i>
ponto_ajustes	ajuste	<i>hora_original</i> , <i>hora_solicitada</i> , <i>motivo</i> , <i>justificativa_id</i> , <i>anexos</i> , <i>status</i> , <i>created_by</i> / <i>created_by_nome</i> , <i>aprovado_por</i> / <i>aprovado_por_nome</i> , <i>data_aprovacao</i> , <i>observacao_aprovador</i>
ponto_audit_log	log	<i>tabela_origem</i> , <i>registro_id</i> , <i>acao</i> , dados_anteriores / dados_novos (JSON da linha inteira), <i>usuario_id</i> , <i>usuario_nome</i> , <i>usuario_email</i> , <i>ip_origem</i> , <i>user_agent</i> , <i>created_at</i>

Lacunas

- **Não há tabela física separada para a marcação original.** Original e inclusão manual convivem na mesma tabela, distinguidas pela flag *marcacao_original*. Ao editar, o valor antigo é substituído na linha e sobrevive apenas dentro do JSON do log.
- **Não existe NSR** gravado — não há coluna para ele. O número é gerado no momento de exportar o AFD (ver item 6).

2

As marcações são imutáveis?

Vedação à alteração da marcação original

NÃO

Confirmado: há edição direta da hora, a partir do papel de gestor.

A observação da consultoria procede. Em *src/hooks/usePonto.ts*, a função **editarMarcacao** executa:

Operação executada hoje

```
UPDATE ponto_marcacoes SET hora_marcacao = ..., marcacao_original = false WHERE id = ...
```

- Disponível a partir do papel **gestor** (*hasMinimumRole("manager")*), **sem** justificativa, evidência ou aprovação. Não há gatilho que impeça UPDATE de hora ou tipo fora do fluxo de ajuste.
- **Sobre a exclusão:** existe gatilho *BEFORE DELETE* nas três tabelas (*ponto_marcacoes*, *ponto_diario*, *ponto_ajustes*), que registra **TENTATIVA_DELETE** e barra o usuário comum. Mas ele consulta *pode_excluir_registro_ponto*, que **libera** para papel $\geq$ gestor e para tipo administrador/gestor — a mesma população que já pode editar. Não é correto dizer que a exclusão está bloqueada.
- Na tabela há apenas políticas de **leitura** e **inserção**. A proteção contra alteração é só por gatilho — e gatilho protege menos que política.

Por que este é o item mais grave

É o único ponto em que o sistema permite **modificar a prova**. Os demais itens são ausência de recurso; este é reescrever o registro original sem rito.

A correção não é difícil: a edição passa a abrir uma solicitação de ajuste — fluxo que já existe, com justificativa, evidência e aprovação —, que insere uma **nova** marcação com *marcacao_original = false* e preserva a original intacta.

3

Existe trilha de auditoria?

Toda alteração de marcação, não só os ajustes formais

SIM*

Para marcações, sim e completa. Não alcança os documentos derivados.

Além do fluxo formal de ajuste, existem **três gatilhos de banco** sobre *ponto_marcacoes*, gravando em *ponto_audit_log*:

Gatilho	Quando dispara	Desde
trigger_audit_marcacoes	AFTER INSERT — toda marcação criada	implantação
trigger_audit_marcacoes_delete	AFTER DELETE — toda exclusão	implantação
trigger_audit_marcacoes_update	AFTER UPDATE — alteração, com antes e depois	07/08/2026

Ressalvas

- A trilha cobre a **marcação**. Não cobre o **dia consolidado** (*ponto_diario*), o **espelho** nem o **fechamento** — e são esses três que viram documento.
- O gatilho de alteração entrou em **07/08/2026**: alterações anteriores não têm o par antes/depois registrado.

4

Existe log de alterações?

Inclusive correção direta em banco, fora do fluxo padrão

SIM*

Pega o que vem de fora da aplicação — mas o log não se protege.

Sim. Como o registro é feito por gatilho na própria tabela, a correção aplicada diretamente no banco (SQL Editor, API de dados) também é capturada, com a linha inteira antes e depois em JSON.

Ressalvas

- Autoria em branco fora da aplicação.** O gatilho grava `auth.uid()`, nulo quando a alteração vem do editor SQL ou de chave de serviço. Registra-se o quê e o quando, não o quem.
- Campos de contexto não preenchidos.** *usuario_nome*, *usuario_email*, *ip_origem* e *user_agent* existem na tabela, mas os gatilhos não os gravam.
- O log não é imutável.** Não há trava contra alteração ou exclusão das próprias linhas de *ponto_audit_log*: quem tem acesso administrativo pode expurgá-lo sem deixar registro.
- Limite técnico conhecido:** um superusuário que desligue os gatilhos (`session_replication_role = replica`) altera sem trilha. Está fora do alcance da aplicação, mas é honesto declarar.

PARCIAL Autoria e contexto fortes na marcação; falta o indicador de origem.

Capturado hoje:

- **quem:** created_by na marcação; created_by e aprovado_por (com nome e data) no ajuste; usuario_id no log;
- **de onde:** ip_origem, user_agent, dispositivo, latitude/longitude, endereço, dentro_cerca, distancia_metros, selfie_url;
- **integridade:** hash SHA-256 por marcação.

Lacunas

- **RN26 não implementada.** Existe apenas *marcacao_original* (sim/não) e *dispositivo* em texto livre — sem as cinco categorias (original, inclusão manual, pré-assinalada, ponto por exceção, outras fontes). A importação de REP-C é a única origem distinguível, por ficar registrada em *ponto_repc_importacoes*.
- No log, os campos de nome, e-mail e IP **não são preenchidos** (ver item 4).

PARCIAL O arquivo é gerado, mas o conteúdo não passaria numa fiscalização.

A suspeita da consultoria procede. O gerador existe e lê marcações reais de *ponto_marcacoes* (em *PontoRelatoriosTab.tsx*), emitindo registros dos tipos 1, 2, 3 e 9. As divergências, somadas das duas auditorias:

Divergência	Como está hoje	Efeito
NSR	Gerado na exportação (1...n do período), 10 dígitos, não persistido	Cada exportação renumera; o NSR precisa ser único, sequencial e permanente
Estrutura do arquivo	Campos de tamanho variável	A norma exige posições fixas
Data / hora	AAAAMMDD e HHMM	O leiaute pede DDMMAAAA e hora com segundos
Tipo do registro	Marcação emitida como tipo 3	Tipo 3 é marcação de REP-C; REP-P usa tipo 7, com assinatura
Registros ausentes	Faltam tipos 4, 5 e 6	Ajuste de relógio, cadastro de empregado e eventos sensíveis
Cabeçalho (tipo 1)	CNPJ + razão social + data/hora	Faltam NSR, tipo de identificador do empregador, CEI/CAEPF, identificação do REP-P e período do arquivo
Trailer (tipo 9)	Um total único	O leiaute pede contagem por tipo de registro
Assinatura	Ausente	Sem hash por registro e sem assinatura do arquivo

Divergência	Como está hoje	Efeito
Escopo	A consulta não filtra empresa	O arquivo sai com o CNPJ da empresa selecionada, mas pode conter marcações de outras empresas do mesmo cliente

Ressalva metodológica

A conferência campo a campo contra o Anexo I deve ser validada pela consultoria, com o texto da norma ao lado. As divergências estruturais acima, porém, independem dessa conferência fina: **NSR não persistido, tamanho variável, ausência de assinatura e mistura de empresas** são impeditivos por si sós.

7

O sistema gera AEJ?

Arquivo Eletrônico de Jornada

NÃO

Não existe gerador. A sigla aparece apenas em texto de ajuda.

AEJ aparece em duas linhas do Guia Rápido do módulo, como texto explicativo — inclusive afirmando que a aba REP-C “armazena os arquivos AFD/AEJ”. Não há geração de jornada contratual, marcações tratadas, horas apuradas nem assinatura do PTRP. A aba REP-C faz o caminho inverso: **importa** AFD de relógio REP-C (*ponto_repc_importacoes*).

Ajuste imediato recomendado

Enquanto o AEJ não existir, o texto do Guia Rápido afirma ao usuário uma conformidade que o sistema não tem. Corrigir a frase leva minutos e evita mal-entendido numa auditoria.

8

O sistema gera Espelho de Ponto?

Espelho de Ponto Eletrônico

SIM*

Existe e está em uso; dois campos aparecem no documento sem serem apurados.

O espelho é gerado no fechamento e gravado em *ponto_espelhos*, com PDF por colaborador: marcações, totais, saldo, ocorrências, resumo mensal e resumo do banco de horas (RN25/27/44). As correções recentes — espelho zerado, isolamento por empresa e dias duplicados — já foram entregues.

Ressalvas

- **Adicional noturno não é apurado.** O campo existe no documento e recebe valor fixo zero (*PontoFechamentoTab.tsx*). Num documento assinado, zero **afirma** que não houve adicional noturno — é declaração, não omissão.
- **HE 50% / 100% passou a ser calculada em 05/08/2026** (RN28). Espelhos emitidos antes dessa data não têm a separação.
- **assinatura_hash existe na tabela mas não é preenchida** pelo fechamento atual.

Existe assinatura digital ICP-Brasil?

Comprovante de marcação, AFD e AEJ

NÃO

Nada no módulo de ponto. Há infraestrutura reaproveitável no eSocial.

O sistema já lida com certificado digital, o que encurta o caminho: o módulo de eSocial usa certificado A1 (.pfx / PKCS#12) com XML-DSig, em *EsocialConfig*, *EsocialTransmissao*, na função *esocial-transmissao* e na tabela *esocial_certificados*, com bucket privado.

No ponto não há assinatura em lugar nenhum — nem no comprovante de marcação, nem no AFD, nem no espelho. O que existe é o **hash SHA-256 por marcação**: detecta adulteração, mas não é assinatura e não substitui a exigência legal.

Existe histórico das alterações?

Histórico técnico completo e imutável

PARCIAL

Completo em conteúdo para marcações; não imutável e sem retenção definida.

Critério	Situação
Fluxo visível de ajuste	Existe — solicitação, justificativa, evidência, aprovação
Histórico técnico de toda alteração	Existe para ponto_marcacoes, com antes e depois em JSON
Cobertura dos documentos	Não — ponto_diario, espelho e fechamento não têm trilha
Imutabilidade do próprio histórico	Não — sem bloqueio de alteração/exclusão sobre o log
Encadeamento de hash entre registros do log	Não existe
Sobrevive a reprocessamento	Sim — reapurar recalcula o dia; não toca nas marcações nem no log
Política de retenção (5 anos)	Não definida

Achado adicional, fora do questionário

Exceção de acesso gravada em código

NÃO

Permissão concedida a um endereço de e-mail específico, fora do modelo de papéis.

Durante a auditoria encontramos, dentro da função de segurança que autoriza a exclusão de registros de ponto (*pode_excluir_registro_ponto*), uma comparação direta com um **endereço de e-mail pessoal**, que devolve autorização antes de qualquer verificação de empresa ou de papel. O mesmo endereço aparece em outros dois pontos do código, como desvio de verificação em módulos distintos.

Por que reportamos isto junto

É uma **permissão que não aparece em nenhuma revisão de acessos**: não está em papel, não está em cadastro de usuário, está escrita no código. Numa auditoria de conformidade, é exatamente o tipo de exceção que precisa ser justificada — e aqui ela não tem justificativa registrada.

Tudo indica ser resquício de teste. A remoção é simples e entra junto com o item 2, que mexe na mesma função. O endereço não foi transcrito neste documento de propósito; está identificado no relato interno.

Backlog unificado

Ordem proposta pelo desenvolvimento, com a justificativa

Prio.	Item	Origem
P0	Encerrar a edição direta de marcação: toda alteração passa pelo fluxo de ajuste, preservando a original. Remover, na mesma função, a exceção por e-mail.	itens 2 e 11
P0	Blindar o <i>ponto_audit_log</i> : negar alteração e exclusão, inclusive a perfis administrativos.	itens 4 e 10
P0	AFD no leiaute oficial: posições fixas, NSR persistido e sequencial, tipos 4/5/6/7, trailer por tipo, filtro por empresa e assinatura.	item 6
P1	Implementar o AEJ e corrigir o texto do Guia Rápido.	item 7
P1	RN26 — indicador de origem por marcação, e preenchimento de nome, e-mail e IP no log.	itens 5 e 4
P1	Estender a trilha a <i>ponto_diario</i> , espelho e fechamento.	item 3
P1	Apurar o adicional noturno ou declará-lo como não apurado no documento, em vez de exibir zero.	item 8
P2	Assinatura ICP-Brasil no comprovante, no AFD e no AEJ, reaproveitando o certificado A1 do eSocial.	item 9
P2	Encadeamento de hash no log e política de retenção de 5 anos.	item 10

Justificativa da ordem

Os dois primeiros P0 são **baratos e imediatos**: um fecha a porta da edição direta, o outro tranca a trilha. Juntos, eliminam a possibilidade de alterar prova sem rastro — a primeira coisa que uma fiscalização pergunta.

O AFD é P0 pelo peso legal, mas é **o mais caro**: exige decidir antes como o NSR será numerado (por empregador ou por equipamento) e reescrever o gerador em posições fixas. Propomos iniciar por essa definição, em conjunto com a consultoria.

O adicional noturno subiu para P1 por um motivo específico: enquanto sai zerado, o documento **afirma** um fato não apurado. Declarar “não apurado” é correção de um dia e remove o risco imediato.

YourEyes · Desenvolvimento · 07/08/2026 — consolidação de duas auditorias independentes do mesmo código, verificadas nesta data. Alterações posteriores podem mudar itens específicos.